PIPELINE SEGURO

Checklist de seguridad para workflows

Repásalo antes de hacer push de cualquier archivo en `.github/workflows/`. Si una casilla queda vacía, el pipeline no está terminado.

Todo workflow

- [ ] **Secretos aparte:** en Settings › Secrets and variables › Actions. Nunca en el código ni en el YAML.
- [ ] **Permisos mínimos:** hay un bloque `permissions:` y parte con `contents: read`.
- [ ] **Versión fija:** cada acción con versión (`@v6`), nunca `@main`. Lo más estricto: el SHA completo.
- [ ] **Logs limpios:** ningún `echo` de un secreto, ni siquiera transformado (base64, subcadenas).
- [ ] **Forks sin secretos:** sabes que un PR desde un fork no recibe tus secretos.
- [ ] **Con límite:** cada job tiene `timeout-minutes`.

Además, si el workflow usa a Claude

- [ ] La Claude GitHub App está instalada en el repo.
- [ ] La credencial es un secreto: `ANTHROPIC_API_KEY` o `CLAUDE_CODE_OAUTH_TOKEN`.
- [ ] `permissions` incluye solo lo necesario: leer código, comentar, leer el CI y `id-token: write`.
- [ ] `claude_args` limita las vueltas: `--max-turns 5`.
- [ ] Si Claude solo debe comentar, `--disallowedTools` le quita las herramientas de edición y de commit.
- [ ] Hay `concurrency`: una ejecución a la vez por hilo.
- [ ] Quien escribe `@claude` tiene permiso de escritura en el repo.

ASÍ NO · ASÍ SÍ

ASÍ NO

```
- run: dotnet test
  env:
    DB_PASSWORD: "pedidos123"
- run: echo "Clave: $DB_PASSWORD"
```

ASÍ SÍ

```
- run: dotnet test
  env:
    DB_PASSWORD: ${{ secrets.DB_PASSWORD }}
# sin echo del secreto
```

⚠ **¿Subiste un secreto por error?** Rótalo de inmediato: genera uno nuevo e invalida el anterior. Borrar el archivo no basta, porque git guarda el historial.

FUENTES

GitHub Docs · Using secrets in GitHub Actions
docs.github.com/en/actions/security-guides/using-secrets-in-github-actions

Claude Code Docs · GitHub Actions
code.claude.com/docs/en/github-actions